Chapter 14 Intro to Networking Exam

Candidate: Dunkan Gibson (dunkan.gibson)
Date: 11/21/2021 8:49:20 am • Time spent: 18:12

Score: 95% Passing Score: 80%

Question 1: ✔ Correct

What does an IDS that uses signature recognition use to identify attacks?

- Statistical analysis to find unusual deviations.
- ➡ Potential attack activity compared to a database of known attacks.
- Current statistics compared to past statistics.
- Exceeding threshold values.

EXPLANATION

Signature recognition, also referred to as pattern matching, dictionary recognition, or misuse detection (MD-IDS), looks for patterns in network traffic and compares them to known attack patterns called signatures.

Anomaly recognition, also referred to as behavior, heuristic, or statistical recognition, monitors traffic to define a standard activity pattern as normal. Clipping levels or thresholds are defined that identify deviations from the norm. When the threshold is reached, an alert is generated or an action is taken. Anomaly-based systems can recognize and respond to some unknown attacks (attacks that do not have a corresponding signature file).

REFERENCES

LabSim for Network Pro, Section 14.1.

Question 2: ✔ Correct

Which of the following activities are considered passive in regards to the function of an intrusion detection system? (Select two.)

- [x] Monitoring the audit trails on a server
- [ ] Transmitting FIN or RES packets to an external host
- [x] Listening to network traffic
- [ ] Disconnecting a port being used by a zombie

EXPLANATION

Passive IDS is a form of IDS that takes no noticeable action on the network. Passive IDS systems are undetectable to intruders. Passive IDS systems can monitor audit trails or listen to network traffic in real time.

Active IDS functions are those that interact with the network and generate detectable events. Such events can include disconnecting ports or transmitting FIN or RES packets to attackers.

REFERENCES

LabSim for Network Pro, Section 14.1.

Question 3: ✔ Correct

Creating fake resources such as honeypots, honeynets, and tarpits fulfills which of the following main intrusion detection and prevention goals? (Select two.)

- [x] Offers attackers a target that occupies their time and attention while distracting them from valid resources.
- [ ] Entices attackers to reveal their IDS signatures, which can then be matched to known attack patterns.
- [ ] Detect anomalous behavior that varies from standard activity patterns, also referred to as heuristic recognition.
- [x] Reveals information about an attacker's methods and gathers evidence for identification or prosecution purposes.
- [ ] Detect attacks that are unique to the services on valid system resources and monitor application activity.
- [ ] Lures attackers into a non-critical network segment where their actions are passively monitored and logged, then shuns the attacker by simply dropping their connection.

EXPLANATION

By using honeypots, honeynets, and tarpits you can fulfill the following intrusion detection and protection goals:

- Attackers are offered targets that will occupy their time and attention, distracting them from valid resources.
- You can observe attackers and gather information about their attack methods or gather evidence for identification or prosecution purposes.

REFERENCES

LabSim for Network Pro, Section 14.1.

Question 4: ✔ Correct

You have just installed a new network-based IDS system that uses signature recognition. What should you do on a regular basis?

- Check for backdoors.
- Modify clipping levels.
- ➡ Update the signature files.
- Generate a new baseline.

EXPLANATION

Signature recognition, also referred to as pattern matching, dictionary recognition, or misuse detection (MD-IDS), looks for patterns in network traffic and compares them to known attack patterns called signatures. Signature-based recognition cannot detect unknown attacks; they can only detect attacks identified by published signature files. For this reason, it is important to update signature files on a regular basis.

Anomaly recognition, also referred to as behavior, heuristic, or statistical recognition, monitors traffic to define a standard activity pattern as normal. Clipping levels or thresholds are defined that identify deviations from the norm. When the threshold is reached, an alert is generated or an action is taken.

REFERENCES

LabSim for Network Pro, Section 14.1.

Question 5: ✔ Correct

If maintaining confidentiality is of the utmost importance to your organization, what is the best response when an intruder is detected on your network?

- Record audit trails about the intruder.
- Delay the intruder.
- Monitor the intruder's actions.
- ➡ Terminate the intruder's session.

EXPLANATION

If maintaining confidentiality is of the utmost importance to your organization, then disconnecting an intruder is the best response. Allowing an intruder to spend any additional time inside of your network once discovered can lead to further breaches of confidentiality.

Delaying, auditing, and monitoring become important responses if prosecution is important.

REFERENCES

LabSim for Network Pro, Section 14.1.

Question 6: ✔ Correct

Members of the sales team use laptops to connect to the company network. While traveling, they connect their laptops to the internet through airport and hotel networks.

You are concerned that these computers will pick up viruses that could spread to your private network. You would like to implement a solution that prevents the laptops from connecting to your network unless anti-virus software and the latest operating system patches have been installed.

Which solution should you use?

- NAT
- ➡ NAC
- DMZ
- VLAN
- NIDS

EXPLANATION

Network Access Control (NAC) controls access to the network by not allowing computers to access network resources unless they meet certain predefined security requirements. Conditions that can be part of the connection requirements include requiring that computers have:

- Anti-virus software with up-to-date definition files
- An active personal firewall
- Specific operating system critical updates and patches

A client that is determined by the NAC agent to be healthy is given access to the network. An unhealthy client who has not met all the checklist requirements is either denied access or can be given restricted access to a remediation network, where remediation servers can be contacted to help the client to become compliant.

A demilitarized zone (DMZ) is a buffer network (or subnet) that sits between the private network and an untrusted network (such as the internet). A virtual LAN (VLAN) is a logical grouping of computers based on switch port. VLAN membership is configured by assigning a switch port to a VLAN. An intrusion detection system (IDS) is a special network device that can detect attacks and suspicious activity. A network-based IDS (NIDS) scans network traffic to look for intrusion attempts.

Network address translation (NAT) modifies the IP addresses in packets as they travel from one network (such as a private network) to another (such as the internet). NAT allows you to connect a private network to the internet without obtaining registered addresses for every host. Hosts on the private network share the registered IP addresses.

REFERENCES

LabSim for Network Pro, Section 14.3.

Question 7: ✔ Correct

To answer this question, complete the lab using the information below.
You have already answered this question.
You are not allowed to view the lab again.

Launch Lab

You completed the lab correctly.

View Lab Report

Question 8: ✔ Correct

You want to make sure that a set of servers will only accept traffic for specific network services. You have verified that the servers are only running the necessary services, but you also want to make sure that the servers will not accept packets sent to those services.

Which tool should you use?

- System logs
- IPS
- Packet sniffer
- IDS
- ➡ Port scanner

EXPLANATION

Use a port scanner to check for open ports on a system or a firewall. Compare the list of opened ports with the list of ports allowed by your network design and security policy. Typically, a port is opened when a service starts or is configured on a device. Open ports for unused services expose the server to attacks directed towards that port.

Use a packet sniffer to examine packets on the network. With a packet sniffer, you can identify packets directed towards specific ports, but you won't be able to tell if those ports are open. Examine system logs to look for events that have happened on a system, which might include a service starting, but would not likely reflect open ports.

An intrusion detection system (IDS) is a special network device that can detect attacks and suspicious activity. A passive IDS monitors, logs, and detects security breaches, but takes no action to stop or prevent the attack. An active IDS (also called an intrusion protection system or IPS) performs the functions of an IDS, but can also react when security breaches occur.

REFERENCES

LabSim for Network Pro, Section 14.1.

Question 9: ✔ Correct

Your company is a small start-up that has leased office space in a building shared by other businesses. All businesses share a common network infrastructure. A single switch connects all devices in the building to the router that provides internet access.

You would like to make sure that your computers are isolated from computers used by other companies. Which feature should you request to have implemented?

- Port security
- Spanning tree
- ➡ VLAN
- VPN

EXPLANATION

Define virtual LANs (VLANs) on the switch. A port on the switch is associated with a VLAN. Only devices connected to ports that are members of the same VLAN can communicate with each other. Routers are used to allow communication between VLANs if necessary.

Use virtual private network (VPN) to securely connect two hosts through an unsecured network (such as the internet). VPN tunneling protocols protect data as it travels through the unsecured network. Spanning tree is a switch feature that allows redundant paths between switches. Port security is a method of requiring authentication before a network connection is allowed.

REFERENCES

LabSim for Network Pro, Section 14.3.

Question 10: ✔ Correct

Match each network enumeration technique on the left with its corresponding description on the right.

Identifying phone numbers with modems

✔ War dialing

Scanning for wireless access points

✔ Wardriving

Identifying operating system type and version number

✔ Banner grabbing

Identifying services that can pass through a firewall

✔ Firewalking

EXPLANATION

Network enumeration (also called network mapping) involves a thorough and systematic discovery of as much of the corporate network as possible. Enumeration methods include:

- Social engineering
- Wardriving (scanning for wireless access points within the organization)
- War dialing (trying to access phone lines that will answer a calling modem)
- Banner grabbing (capturing information transmitted by the remote host including the application type, application version, and even operating system type and version)
- Firewalking (using traceroute techniques to discover which services can pass through a firewall or a router)
- Probing the corporate network with scanning tools, often using the same tools used by hackers, such as SATAN and Nessus
- Monitoring the network (usually performed from a remote site)
- Soliciting host-specific banners to identify the function of a remote host

REFERENCES

LabSim for Network Pro, Section 14.2.

Question 11: ✔ Correct

Which of the following intrusion detection and prevention systems uses fake resources to entice intruders by displaying a vulnerability, configuration flaw, or valuable data?

- ➡ Honeypot
- Trojan horse
- Zombie
- Botnet

EXPLANATION

A honeypot is a device or virtual machine that entices intruders by displaying a vulnerability, displaying a configuration flaw, or appearing to contain valuable data.

A Trojan horse is a malicious program that is disguised as legitimate or desirable software. A zombie is a computer that is infected with malware that allows remote software updates and control by a command and control center called a zombie master. A botnet refers to a group of zombie computers that are commanded from a central control infrastructure.

REFERENCES

LabSim for Network Pro, Section 14.1.

Question 12: ✔ Correct

What does a tarpit specifically do to detect and prevent intrusion into your network?

- Passively monitors and logs suspicious activity until it detects a known attack pattern, then shuns the intruder by dropping their connection.
- Entices intruders by displaying a vulnerability, configuration flow, or data that appears to be of value.
- ➡ Answers connection requests in such a way that the attacking computer is stuck for a period of time.
- Uses a packet sniffer to examine network traffic and identify known attack patterns, then locks the attacker's connection to prevent any further intrusion activities.

EXPLANATION

A tarpit (also called a sticky honeypot) is a honeypot that answers connection requests in such a way that the attacking computer is stuck for a period of time.

REFERENCES

LabSim for Network Pro, Section 14.1.

Question 13: ✔ Correct

Match the port security MAC address type on the left with its description on the right.

A MAC address manually identified as an allowed address.

✔ SecureConfigured

A MAC address that has been learned and allowed by the switch.

✔ SecureDynamic

A MAC address that is manually configured or dynamically learned that is saved in the config file.

✔ SecureSticky

EXPLANATION

MAC addresses are stored in RAM in the CAM table and are identified with the port and by a MAC address type. Port security uses the following three MAC address types:

Type	Description
SecureConfigured	A SecureConfigured address is a MAC address that has been manually identified as an allowed address.
SecureDynamic	A SecureDynamic address is a MAC address that has been dynamically learned and allowed by the switch.
SecureSticky	A SecureSticky address is a MAC address that is manually configured or dynamically learned and saved.

REFERENCES

LabSim for Network Pro, Section 14.3.

Question 14: ✔ Correct

Which of the following is a security service that monitors network traffic in real time or reviews the audit logs on servers looking for security violations?

- Padded cell
- ➡ IDS
- Switch
- Firewall

EXPLANATION

An IDS (Intrusion Detection System) is a security service that monitors network traffic in real time or reviews the audit logs on servers looking for security violations.

Firewalls filter traffic crossing a border of a network environment in order to block unauthorized or security-violating traffic. A switch is a networking device used to establish temporary electronically dedicated links between two systems to improve throughput and communications isolation. A padded cell is a fake network environment generated to lure and snare intruders.

REFERENCES

LabSim for Network Pro, Section 14.1.

Question 15: ✕ Incorrect

A network switch detects a DHCP frame on the LAN that appears to have come from a DHCP server that is not located on the local network. In fact, it appears to have originated from outside the organization's firewall.

As a result, the switch drops the DHCP message from that server.

Which security feature was enabled on the switch to accomplish this?

- ~~Dynamic ARP inspection~~
- DHCP snooping
- IGMP snooping
- Port security

EXPLANATION

Some switches provide DHCP snooping as a security feature. DHCP snooping filters untrusted DHCP messages. An untrusted DHCP message is received from outside the network or firewall. DHCP snooping acts like a firewall between DHCP clients and your DHCP servers. The switch maintains a DHCP snooping binding table that matches MAC addresses with DHCP messages. When DHCP snooping is enabled, the switch drops DHCP messages if the frame from the DHCP server is received from outside the network or firewall. It also drops DHCP messages if the source MAC address and the DHCP client MAC address do not match in the DHCP snooping binding table.

IGMP snooping allows a switch to control which ports get IGMP traffic for a specific group. Port security restricts which hosts can connect to a switch port based on MAC addresses. Dynamic ARP Inspection is designed to prevent man-in-the middle attacks by validating ARP packets on the network.

REFERENCES

LabSim for Network Pro, Section 14.3.

Question 16: ✔ Correct

Properly configured passive IDS and system audit logs are an integral part of a comprehensive security plan. What step must be taken to ensure that the information is useful for maintaining a secure environment?

- All files must be verified with the IDS checksum.
- ➡ Periodic reviews must be conducted to detect malicious activity or policy violations.
- All logs should be deleted and refreshed monthly.
- The accounting department must compress the logs on a quarterly basis.

EXPLANATION

Audit logs are useless unless they are periodically reviewed. The frequency will vary based on the criticality of the system being monitored, but the logs must be reviewed on a scheduled basis by a knowledgeable member of the IT/Infosec team.

REFERENCES

LabSim for Network Pro, Section 14.1.

Question 17: ✔ Correct

As a security precaution, you have implemented IPsec between any two devices on your network. IPsec provides encryption for traffic between devices.

You would like to implement a solution that can scan the contents of the encrypted traffic to prevent any malicious attacks.

Which solution should you implement?

- Network-based IDS
- Protocol analyzer
- ➡ Host-based IDS
- VPN concentrator
- Port scanner

EXPLANATION

A host-based IDS is installed on a single host and monitors all traffic coming in to the host. A host-based IDS can analyze encrypted traffic because the host operating system decrypts that traffic as it is received.

A network-based IDS is a dedicated device installed on the network. It analyzes all traffic on the network. It cannot analyze encrypted traffic because the packet contents are encrypted so that only the recipient can read the packet contents.

A protocol analyzer examines packets on the network, but cannot look at the contents of encrypted packets. A port scanner probes a device to identify open protocol ports. A VPN concentrator is a device that is used to establish remote access VPN connections.

REFERENCES

LabSim for Network Pro, Section 14.1.

Question 18: ✔ Correct

Which IDS method searches for intrusion or attack attempts by recognizing patterns or identities listed in a database?

- Anomaly-analysis-based
- ➡ Signature-based
- Heuristics-based
- Stateful-inspection-based

EXPLANATION

A signature-based, or pattern-matching-based, IDS is a detection system that searches for intrusion or attack attempts by recognizing patterns that are listed in a database.

A heuristics-based IDS is able to perform some level of intelligent statistical analysis of traffic to detect attacks. Anomaly-analysis-based IDS looks for changes to the normal patterns of traffic. A stateful-inspection-based IDS searches for attacks by inspecting packet contents and associating one packet with another, looking for attacks in overall data streams rather than individual packets.

REFERENCES

LabSim for Network Pro, Section 14.1.

Question 19: ✔ Correct

You have worked as the network administrator for a company for seven months. One day, all picture files on the server become corrupted.

You discover that a user downloaded a virus from the internet onto his workstation, and it propagated to the server. You successfully restore all files from backup, but your boss is adamant that this situation does not reoccur.

What should you do?

- Disconnect the user from the internet.
- Allow users to access the internet only from terminals that are not attached to the main network.
- ➡ Install a network virus detection software solution.
- Install a firewall.

EXPLANATION

Virus detection software can almost eliminate the threat of viruses on your network. Versions exist that automatically update virus databases every time you connect to the internet. A network solution is preferable because it is less expensive and easier to administer than individual workstation software.

REFERENCES

LabSim for Network Pro, Section 14.1.

Question 20: ✔ Correct

In which of the following situations would you use port security?

- ➡ You want to restrict the devices that could connect through a switch port.
- You want to prevent MAC address spoofing.
- You want to prevent sniffing attacks on the network.
- You want to control the packets sent and received by a router.

EXPLANATION

Use port security on a switch to restrict the devices that can connect to a switch. Port security uses the MAC address to identify allowed and denied devices. When an incoming frame is received, the switch examines the source MAC address to decide whether to forward or drop the frame.

Port security cannot prevent sniffing or MAC address spoofing attacks. Use an access list on a router to control sent and received packets.

REFERENCES

LabSim for Network Pro, Section 14.3.

Question 21: ✔ Correct

A security administrator is conducting a penetration test on a network. She connects a notebook system to a mirror port on a network switch. She then uses a packet sniffer to monitor network traffic to try and determine which operating systems are running on network hosts.

Which process did the administrator use in the penetration test in this scenario?

- Firewalking
- Network enumeration
- Active fingerprinting
- ➡ Passive fingerprinting

EXPLANATION

The administrator in this scenario used passive fingerprinting. Passive fingerprinting is a form of system enumeration that is designed to gain as much information about network computers as possible. It passively listens to network traffic generated by network hosts and attempts to identify which operating systems are in use based upon the ICMP message quoting characteristics they use. Portions of original ICMP requests are repeated (or quoted) within each response. Each operating system quotes this information back in a slightly different manner.

Active fingerprinting works in much the same manner as passive fingerprinting. However, it utilizes active probes of specific systems instead of passive monitoring. Network enumeration (also called network mapping) involves a thorough and systematic discovery of as much of the corporate network as possible, using:

- Social engineering
- Wardriving
- War dialing
- Banner grabbing
- Firewalking

Firewalking uses traceroute techniques to discover which services can pass through a firewall or a router. Hping and Firewalk are common firewalking tools.

REFERENCES

LabSim for Network Pro, Section 14.2.

Question 22: ✔ Correct

You have decided to perform a double-blind penetration test. Which of the following actions should you perform first?

- ➡ Inform senior management.
- Run system fingerprinting software.
- Engage in social engineering.
- Perform operational reconnaissance.

EXPLANATION

Before starting a penetration test (also called a pen test) it is important to define the rules of engagement (ROE), or the boundaries of the test. Important actions to take include:

- Obtain a written and signed authorization from the highest possible senior management.
- Delegate personnel who are experts in the areas being tested.
- Gain approval from the internet provider to perform the penetration test.
- Make sure that all tools or programs used in the testing are legal and ethical.
- Establish the scope and timeline.
- Identify systems that will not be included in the test.

Performing reconnaissance, social engineering, or system scanning are all actions performed during a penetration test. However, no actions should be taken before approval to conduct the test is obtained.

REFERENCES

LabSim for Network Pro, Section 14.2.

Question 23: ✔ Correct

Which of the following devices can monitor a network and detect potential security attacks?

- Proxy
- DNS server
- IDS
- Load balancer
- CSU/DSU

EXPLANATION

An intrusion detection system (IDS) is a special network device that can detect attacks and suspicious activity.

A proxy server is a type of firewall that can filter based on upper-layer data. A CSU/DSU is a device that converts the signal received from the WAN provider into a signal that can be used by equipment at the customer site. A DNS server provides IP address-to-host-name resolution. Load balancing configures a group of servers in a logical group (called a server farm). Incoming requests to the group are distributed to individual members within the group.

REFERENCES

LabSim for Network Pro, Section 14.1.

Question 24: ✔ Correct

Match the network access protection (NAP) component on the left with its description on the right.

Generates a statement of health (SoH) that reports the client configuration for health requirements.

✔ NAP client

Runs the System Health Validator (SHV) program.

✔ NAP server

Is clients' connection point to the network.

✔ Enforcement server (ES)

Contain resources accessible to non-compliant computers on the limited-access network.

✔ Remediation server

EXPLANATION

NAP uses the following components:

- The NAP client generates a statement of health (SoH) that reports the client configuration for health requirements.
- A NAP server runs the System Health Validator (SHV).
- The enforcement server (ES) is clients' connection point to the network.
- The remediation server contain resources accessible to non-compliant computers on the limited-access network.

REFERENCES

LabSim for Network Pro, Section 14.3.

Question 25: ✔ Correct

Which of the following activities are typically associated with a penetration test? (Select two.)

- [ ] Running a vulnerability scanner on network servers
- [x] Attempting social engineering
- [ ] Creating a performance baseline
- [ ] Interviewing employees to verify the security policy is being followed
- [x] Running a port scanner

EXPLANATION

Penetration testing is when an organization attempts to circumvent security controls to identify vulnerabilities in their information systems. It simulates an actual attack on the network and is conducted from outside the organization's security perimeter. Penetration testing helps assure the effectiveness of an organization's security policy, security mechanism implementations, and deployed countermeasures.

Penetration testing typically uses tools and methods that are available to attackers. Penetration testing might start with attempts at social engineering or other reconnaissance activities followed by more active scans of systems and then actual attempts to access secure systems.

A vulnerability scanner checks a system for weaknesses. Vulnerability scanners typically require administrative access to a system and are performed internally to check for weaknesses, but not to test system security. Penetration testers are not typically able to run a vulnerability scanner unless they have been able to gain unauthorized access to a system.

A performance baseline is created by an administrator to identify normal network and system performance. Auditing might include interviewing employees to make sure that security policies are being followed.

REFERENCES

LabSim for Network Pro, Section 14.2.

Question 26: ✔ Correct

You are concerned about attacks directed at your network firewall. You want to be able to identify attacks and be notified of attacks. In addition, you want the system to take immediate action when possible to stop or prevent the attack.

Which tool should you use?

- Packet sniffer
- ➡ IPS
- IDS
- Port scanner

EXPLANATION

Use an intrusion prevention system (IPS) to both detect and respond to attacks. An intrusion detection system (IDS) can detect attacks and send notifications, but cannot respond to attacks.

Use a port scanner to check for open ports on a system or a firewall. Use a packet sniffer to examine packets on the network.

REFERENCES

LabSim for Network Pro, Section 14.1.

Question 27: ✔ Correct

You have a company network with a single switch. All devices connect to the network through the switch.

You want to control which devices will be able to connect to your network. For devices that do not have the latest operating system patches, you want to prevent access to all network devices except for a special server that holds the patches that the computers need to download.

Which of the following components will be part of your solution? (Select two.)

- [ ] DMZ
- [x] 802.1x authentication
- [ ] Extranet
- [x] Remediation servers
- [ ] Honeypot

EXPLANATION

Network access control (NAC) controls access to the network by not allowing computers to access network resources unless they meet certain predefined security requirements. NAC can be used with 802.1x port authentication on a switch to allow or deny access to the network through the switch port. A client that is determined by the NAC agent to be healthy is given access to the network. An unhealthy client who has not met all the checklist requirements is either denied access or given restricted access to a remediation network, where remediation servers can help the client to become compliant. For example, remediation servers might include anti-virus software and definition files that can be installed. If and when the unhealthy client's status changes to healthy, the client is given access to the network.

A demilitarized zone (DMZ) is a buffer network (or subnet) that sits between the private network and an untrusted network (such as the internet). DMZs are created with routers and firewall rules to allow or block traffic. DMZs use information in the packet to allow or deny packets.

An extranet is a privately-controlled network that is distinct from but located between the internet and a private LAN. An extranet is often used to grant resource access to business partners, suppliers, and even customers outside of the organization. A honeypot is a device or virtual machine that entices intruders by displaying a vulnerable trait or flaw or by appearing to contain valuable data.

REFERENCES

LabSim for Network Pro, Section 14.3.

Question 28: ✔ Correct

What security mechanism can be used to detect attacks originating on the internet or from within an internal trusted subnet?

- Firewall
- ➡ IDS
- Biometric system
- Security alarm

EXPLANATION

An IDS is a security mechanism that can detect attacks originating on the internet or from within an internal trusted subnet.

A firewall is only able to filter traffic crossing through its interfaces. Therefore, it is unlikely to detect attacks within trusted areas that are not being filtered. A security alarm is a form of physical intrusion detection. Therefore, it is not suited for detecting electronic or online attacks. Biometric systems are a form of authentication mechanism; they are not a detection mechanism.

REFERENCES

LabSim for Network Pro, Section 14.1.

Question 29: ✔ Correct

An active IDS system often performs which of the following actions? (Select two.)

- [x] Update filters to block suspect traffic.
- [ ] Trap and delay the intruder until the authorities arrive.
- [x] Perform reverse lookups to identify an intruder.
- [ ] Request a second logon test for users performing abnormal activities.

EXPLANATION

An active IDS performs behaviors that can be seen by anyone watching the network. Usually, these actions are necessary to block malicious activities or discover the identity of an intruder. Updating filters and performing reverse lookups are common behaviors for an active IDS.

No form of IDS requires users to perform a second logon based on questionable activities. There are some authentication systems, such as CHAP, that periodically re-authenticate, but this is done at random time intervals, and the action is not visible to the user. A solution that serves to trap and delay the intruder until the authorities arrive describes a man trap (a physical security mechanism). However, this definition could be stretched to include honey pots and padded cells (logical or technical security mechanisms often used in conjunction with an IDS).

REFERENCES

LabSim for Network Pro, Section 14.1.

Question 30: ✔ Correct

What is the primary purpose of penetration testing?

- Evaluate newly deployed firewalls.
- Infiltrate a competitor's network.
- ➡ Test the effectiveness of your security perimeter.
- Assess the skill level of new IT security staff.

EXPLANATION

The primary purpose of penetration testing is to test the effectiveness of your security perimeter. Only by attempting to break into your own secured network can you be assured that your security policy, security mechanism implementations, and deployed countermeasures are effective. It is important to obtain senior management approval before starting a penetration testing or vulnerability scanning project. Often, penetration testing or vulnerability scanning is performed by an external consultant or security outsourcing agency that is hired by your organization.

REFERENCES

LabSim for Network Pro, Section 14.2.

Question 31: ✔ Correct

Which of the following is the most common detection method used by an IDS?

- Behavior
- Anomaly
- ➡ Signature
- Heuristic

EXPLANATION

Signature recognition, also referred to as pattern matching, dictionary recognition, or misuse detection (MD-IDS), looks for patterns in network traffic and compares them to known attack patterns called signatures. Signature recognition is the most common IDS recognition type.

Anomaly recognition, also referred to as behavior, heuristic, or statistical recognition, monitors traffic to define a standard activity pattern as normal. Clipping levels or thresholds are defined that identify deviations from the norm. When the threshold is reached, an alert is generated or an action is taken.

REFERENCES

LabSim for Network Pro, Section 14.1.

Question 32: ✔ Correct

Which of the following are security devices that perform stateful inspection of packet data, looking for patterns that indicate malicious code? (Select two.)

- [ ] Firewall
- [x] IDS
- [ ] VPN
- [x] IPS
- [ ] ACL

EXPLANATION

An intrusion detection system (IDS) and an intrusion prevention system (IPS) are devices that scan packet contents looking for patterns that match known malicious attacks. Signature files identify the patterns of all known attacks. When a packet matches the pattern indicated in the signature file, the packet can be dropped or an alert can be sent.

Firewalls use an access control list (ACL) to filter packets based on the packet header (not data) information. Firewalls can filter packets based on port, protocol, or IP address. A virtual private network (VPN) is an encrypted communication channel established between two entities to exchange data over an unsecured network.

REFERENCES

LabSim for Network Pro, Section 14.1.

Question 33: ✕ Incorrect

To answer this question, complete the lab using the information below. **Launch Lab**

You did not attempt the lab.

Question 34: ✔ Correct

You are concerned about protecting your network from network-based attacks from the internet. Specifically, you are concerned about zero day attacks (attacks that have not yet been identified or that do not have prescribed protections).

Which type of device should you use?

- Signature-based IDS
- ➡ Anomaly-based IDS
- Host-based firewall
- Network-based firewall
- Anti-virus scanner

EXPLANATION

An anomaly-based intrusion detection system (IDS) can recognize and respond to some unknown attacks. Signature recognition, also referred to as pattern matching or dictionary recognition, looks for patterns in network traffic and compares them to known attack patterns called signatures. Signature-based recognition cannot detect unknown attacks; they can only detect attacks identified by published signature files.

Anti-virus software is a form of signature-based IDS. A network-based firewall filters packets for a network, while a host-based firewall filters packets for a host. Firewalls are typically configured using access control lists that identify specific traffic that is allowed or denied.

REFERENCES

LabSim for Network Pro, Section 14.1.

Question 35: ✔ Correct

A security administrator is conducting a penetration test on a network. She connects a notebook system running Linux to the wireless network and then uses NMAP to probe various network hosts to see which operating system they are running.

Which process did the administrator use in the penetration test in this scenario?

- ➡ Active fingerprinting
- Passive fingerprinting
- Network enumeration
- Firewalking

EXPLANATION

The administrator in this scenario used active fingerprinting. Active fingerprinting is a form of system enumeration that is designed to gain as much information about a specific computer as possible. It identifies operating systems based upon ICMP message quoting characteristics. Portions of an original ICMP request are repeated (or quoted) within the response, and each operating system quotes this information back in a slightly different manner. Active fingerprinting can determine the operating system and even the patch level.

Passive fingerprinting works in much the same manner as active fingerprinting. However, it does not utilize the active probes of specific systems. Network enumeration (also called network mapping) involves a thorough and systematic discovery of as much of the corporate network as possible, using:

- Social engineering
- Wardriving
- War dialing
- Banner grabbing
- Firewalking

Firewalking uses traceroute techniques to discover which services can pass through a firewall or a router. Hping and Firewalk are common firewalking tools.

REFERENCES

LabSim for Network Pro, Section 14.2.

Question 36: ✔ Correct

Which of the following devices is capable of detecting and responding to security threats?

- IDS
- ➡ IPS
- DNS server
- Multilayer switch

EXPLANATION

An intrusion prevention system (IPS) can detect and respond to security events. An IPS differs from an IDS because it can respond to threats; and IDS only detects threats.

A DNS server provides IP address-to-host-name resolution. A multilayer switch uses an ASIC module to switch packets based on packet or data content instead of using the CPU and software.

REFERENCES

LabSim for Network Pro, Section 14.1.

Question 37: ✔ Correct

You manage a network that uses switches. In the lobby of your building are three RJ45 ports connected to a switch.

You want to make sure that visitors cannot plug in their computers into the free network jacks and connect to the network, but you want employees who plug into those same jacks should be able to connect to the network.

What feature should you configure?

- VLANs
- ➡ Port authentication
- Bonding
- Mirroring
- Spanning tree

EXPLANATION

Use port authentication to prevent unauthorized access through switch ports. Port authentication is provided by the 802.1x protocol and allows only authenticated devices to connect to the LAN through the switch. Authentication uses usernames and passwords, smart cards, or other authentication methods.

- When a device first connects, the port is set to an unauthorized state. Ports in unauthorized states can only be used for 802.1x authentication traffic.
- After the server authenticates the device or the user, the switch port is placed in an authorized state, and access to other LAN devices is allowed.

With a VLAN, you assign each port to a VLAN. If the ports in the lobby were assigned to one VLAN, you could control the type of access through the switch for those ports, but could not modify the access based on user. If you use a VLAN, both visitors and employees would have the same access through those ports.

Spanning tree is a protocol on a switch that allows the switch to maintain multiple paths between switches within a subnet. The spanning tree protocol runs on each switch and is used to select a single path between any two switches. Mirroring sends traffic from all switch ports to a switch port you designate as the mirrored port. Bonding allows multiple switch ports to be used at the same time to reach a specific destination.

REFERENCES

LabSim for Network Pro, Section 14.3.

Question 38: ✔ Correct

Which of the following actions should you take to reduce the attack surface of a server?

- Install the latest patches and hotfixes.
- Install a host-based IDS.
- ➡ Disable unused services.
- Install anti-malware software.

EXPLANATION

Attack surface reduction (ASR) cuts down on the software or services running on a system. By removing unnecessary software, features, or services, you eliminate possible attacks directed at those components. When removing unnecessary components:

- Use role separation by installing services on separate physical systems. If a single system is compromised, only the few services on that system will be affected.
- For many new systems, unnecessary services are often installed by default. Following installation, you should remove unneeded services, protocols, and applications.
- When removing existing services, determine the unneeded services and their dependencies before altering the system.

Adding anti-malware or a host-based IDS adds a level of protection (defense in depth), but does not reduce the number of components running on the system. Applying patches is necessary to fix security problems with software or the operating system, but if the system is not running a specific piece of software, the patches that apply to that software are irrelevant and will not need to be applied.

REFERENCES

LabSim for Network Pro, Section 14.3.

Question 39: ✔ Correct

Which of the following uses hacking techniques to proactively discover internal vulnerabilities?

- ➡ (●) Penetration testing
- ( ) Inbound scanning
- ( ) Passive reconnaissance
- ( ) Reverse engineering

EXPLANATION

Penetration testing is the practice of proactively testing systems and policies for vulnerabilities. This approach seeks to identify vulnerabilities internally before a malicious individual can take advantage of them. Common techniques are identical to those used by hackers and include network/target enumeration and port scanning.

REFERENCES

LabSim for Network Pro, Section 14.2.

Question 40: ✔ Correct

What actions can a typical passive intrusion detection system (IDS) take when it detects an attack? (Select two.)

- [ ] The IDS configuration is changed dynamically, and the source IP address is banned.
- [ ] LAN-side clients are halted and removed from the domain.
- ➡ [x] An alert is generated and delivered via email, the console, or an SNMP trap.
- ➡ [x] The IDS logs all pertinent data about the intrusion.

EXPLANATION

The main functions of a passive IDS are to log suspicious activity and generate alerts if the attack is deemed severe. Additional functionality can be achieved by using a more advanced type of IDS called an active IDS. An active IDS can automate responses that may include dynamic policy adjustment and reconfiguration of supporting network devices to block the offending traffic.

REFERENCES

LabSim for Network Pro, Section 14.1.

Copyright © 2021 TestOut Corporation All rights reserved.